Protección de terminales

Análisis de seguridad de hosts Linux con Lynis, OpenVAS y una distribución orientada a seguridad.

Objetivos de la clase

- Comprender por qué la protección del endpoint forma parte de la seguridad de una organización.
- Relacionar superficie de ataque, firewall basado en host, HIDS y evaluación de vulnerabilidades.
- Realizar una auditoría local de un host Linux utilizando Lynis.
- Detectar una falencia, corregirla y comparar el reporte antes y después.
- Realizar una evaluación con OpenVAS/Greenbone y analizar sus resultados.
- Repetir el proceso desde una distribución Linux orientada a seguridad y comparar enfoques.

¿Por qué proteger los terminales?

- Las organizaciones necesitan conectarse a redes públicas para acceder a Internet y ofrecer servicios.
- Cada host conectado puede convertirse en un punto de entrada, persistencia o movimiento lateral.
- La seguridad no termina en el perímetro: un atacante que compromete un host interno puede utilizarlo como punto de partida para alcanzar otros sistemas.
- La evaluación periódica permite descubrir configuraciones débiles y vulnerabilidades antes de que sean aprovechadas.
- La tarea de laboratorio debe realizarse exclusivamente sobre sistemas propios o sobre los que exista autorización explícita.

Superficie de ataque

- La superficie de ataque es el conjunto de vulnerabilidades y puntos expuestos a los que potencialmente puede acceder un atacante.
- Incluye puertos y servicios de red, aplicaciones, software del sistema operativo, protocolos, configuraciones y cuentas.
- En Linux, la superficie puede reducirse deshabilitando servicios innecesarios, limitando puertos, aplicando actualizaciones y configurando correctamente el acceso remoto.
- La superficie de ataque cambia con el tiempo: instalar software, habilitar un servicio o modificar una regla de firewall puede aumentarla o reducirla.

Comandos Ubuntu: Identificación & Sockets

1. Verificar versión exacta del Kernel y OS
uname -r && lsb_release -a

2. Auditar sockets TCP/UDP en escucha con PID/Proceso
sudo ss -tulpn
sudo netstat -l

3. Listar archivos y sockets abiertos por red
sudo lsof -i -P -n | grep LISTEN

4. Servicios habilitados al inicio del sistema
systemctl list-unit-files --state=enabled –type=service

```
# 5. nc -zv 127.0.0.1 22
printf "GET / HTTP/1.1\r\nHost:
www.google.com\r\nConnection: close\r\n\r\n" | nc
www.google.com 80
```

Defensa en profundidad en un host Linux

- No existe una única herramienta que garantice la seguridad del endpoint.
- Controles preventivos: actualizaciones, mínimo privilegio, autenticación fuerte, firewall y desactivación de servicios innecesarios.
- Controles de detección: logs, HIDS, comprobación de integridad y monitoreo.
- Evaluación: auditorías de configuración y escáneres de vulnerabilidades.
- El objetivo es combinar controles para que una falla individual no implique automáticamente el compromiso del sistema.

Comandos Ubuntu: Configuración UFW

```
# Estado detallado de UFW
sudo ufw status verbose

# Configurar política por defecto
sudo ufw default deny incoming
sudo ufw default allow outgoing

# Permitir SSH restrictivo por IP/Subred
sudo ufw allow from 192.168.1.0/24 to any port 22 proto tcp

# Inspeccionar reglas traducidas en nftables
sudo nft list ruleset | head -n 20
```

HIDS: detección basada en el host

- Un HIDS monitorea el propio sistema para detectar comportamientos, cambios o eventos sospechosos.
- Puede analizar registros, configuración, procesos y cambios en archivos.
- Las detecciones pueden basarse en firmas, anomalías o políticas predefinidas.
- El concepto complementa al firewall: el firewall controla comunicaciones; el HIDS observa actividad y cambios en el sistema.
- Ejemplos históricos del material de referencia incluyen OSSEC y herramientas de integridad como Tripwire.

AppArmor: Control de acceso obligatorio (MAC) nativo activo.

Auditd: Subsistema del kernel para auditoría de llamadas al sistema.

Wazuh / **AIDE**: Estándar actual para FIM (File Integrity Monitoring) y HIDS distribuido.

Comandos Ubuntu: Verificación HIDS & MAC

1. Estado de perfiles AppArmor
sudo aa-status

2. Reglas activas del subsistema de auditoría
apt-get install auditd audispd-plugins
sudo auditctl -l
https://medium.com/@boristheblade1/configuring-auditd-in-linux-6d1f6e100079https://www.redhat.com/en/blog/configure-linux-auditing-auditd

3. Inicializar / Verificar AIDE (File Integrity)
sudo aideinit && sudo aide --check

4. Estado del agente Wazuh (si está desplegado)
sudo systemctl status wazuh-agent

Dos tipos de evaluación

- Auditoría local: la herramienta se ejecuta en el propio host y analiza su configuración y postura de seguridad.
- Escaneo remoto: una herramienta desde otro sistema identifica servicios, versiones y vulnerabilidades accesibles por red.
- Un análisis con credenciales puede obtener información más profunda porque puede revisar el sistema desde dentro.
- Por eso Lynis y OpenVAS no son equivalentes: responden preguntas diferentes y sus resultados se complementan.

Lynis: auditoría de seguridad en Linux

- Lynis es una herramienta de auditoría para sistemas tipo Unix/Linux.
- Realiza comprobaciones sobre configuración, servicios, autenticación, permisos, kernel, red, logging y otros componentes.
- El resultado incluye advertencias y sugerencias que permiten priorizar mejoras.
- Su valor principal en esta práctica es observar el estado del host antes y después de una modificación concreta.
- La puntuación o el resultado global debe interpretarse junto con las advertencias: una mejora numérica no implica que todo el sistema sea seguro.

Preparación del laboratorio con Lynis

- Utilizar una máquina virtual o un host Linux de laboratorio para evitar afectar sistemas productivos.
- Actualizar los paquetes del sistema antes de comenzar, registrando qué cambios se realizan.
- Instalar Lynis desde el mecanismo de paquetes de la distribución o desde una fuente confiable.
- Guardar el reporte inicial y anotar la fecha, versión del sistema, versión de Lynis y configuración relevante.
- No modificar múltiples controles simultáneamente si se quiere medir con claridad el impacto de una corrección.

Primera ejecución: línea de base

La primera auditoría debe considerarse una línea de base. El objetivo no es corregir inmediatamente todo lo que aparezca, sino identificar una o más falencias relevantes, comprender su causa y seleccionar una corrección controlada.

- Registrar advertencias, sugerencias y pruebas relevantes.
- Elegir una falencia que sea segura de corregir en el entorno de laboratorio.
- Documentar el estado original antes de modificar el sistema.

Ejemplo de falencia: servicio innecesario

- Una situación típica es encontrar un servicio de red habilitado que no es necesario para el propósito del host.
- La corrección consiste en determinar qué servicio es, comprobar sus dependencias y detenerlo/deshabilitarlo si realmente no es requerido.
- Antes de actuar hay que verificar que el servicio no sea utilizado por otra función del sistema.
- Después de la modificación se vuelve a ejecutar Lynis y se comparan los resultados.
- La evidencia debe mostrar qué recomendación estaba presente, qué cambio se hizo y qué cambió en el reporte.

Antes y después: ¿qué medir?

- Cantidad y severidad de advertencias relevantes.
- Resultado o hardening index reportado por Lynis, cuando corresponda.
- Recomendaciones asociadas a la configuración modificada.
- Servicios o puertos que dejaron de estar expuestos.
- Impacto operativo: comprobar que el host sigue cumpliendo su función.
- No presentar una mejora de puntuación como prueba absoluta de seguridad: es un indicador dentro de una auditoría.

Comandos Ubuntu: Remediación & Validación

```
# 1. Detener y deshabilitar servicio no requerido
sudo systemctl stop avahi-daemon
sudo systemctl disable avahi-daemon

# 2. Enmascarar servicio (previene activación indirecta)
sudo systemctl mask avahi-daemon

# 3. Verificar que la puerta/puerto quedó cerrada
sudo ss -tulpn | grep 5353

# 4. Comparar reportes antes y después
diff -u report-before.dat report-after.dat
```

Preguntas que debe responder el informe

- ¿Qué falencia detectaron?
- ¿Por qué representa un riesgo?
- ¿Qué evidencia proporcionó Lynis?
- ¿Cómo la repararon?
- ¿Qué precauciones tomaron antes de modificar el sistema?
- ¿Qué cambió en el reporte posterior?
- ¿La corrección tuvo algún impacto sobre la disponibilidad o funcionalidad del host?

OpenVAS / Greenbone

- OpenVAS forma parte del ecosistema de evaluación de vulnerabilidades de Greenbone.
- A diferencia de una auditoría local como Lynis, un escáner de vulnerabilidades busca identificar problemas en servicios y sistemas accesibles por red.
- La evaluación puede realizarse de forma remota y puede incorporar credenciales para obtener información adicional del host.
- Los resultados incluyen vulnerabilidades, severidades y evidencias que deben analizarse antes de decidir una remediación.

Conceptos: Target, Task y Credentials

• Target: define el sistema o conjunto de sistemas que se va a evaluar, incluyendo sus direcciones y parámetros de escaneo.

• Task: define la ejecución del análisis, incluyendo el target y la configuración del escaneo.

• Credentials: permiten realizar comprobaciones autenticadas, por ejemplo mediante SSH, cuando la configuración del laboratorio lo permite.

• El escaneo autenticado puede revelar información que no es visible desde el exterior.

• Las credenciales deben ser de laboratorio y con privilegios mínimos compatibles con las comprobaciones necesarias.

Secuencia de laboratorio con OpenVAS

- 1. Preparar el host Linux objetivo y comprobar conectividad desde la máquina que ejecutará el escaneo.
- 2. Crear el Target con la dirección del host autorizado.
- 3. Configurar las credenciales SSH si se utilizará un análisis autenticado.
- 4. Crear una nueva Task asociada al Target y ejecutar el escaneo.
- 5. Analizar los resultados y seleccionar una falencia relevante y corregible.
- 6. Aplicar la remediación en el host.
- 7. Ejecutar nuevamente el análisis y comparar el resultado.

Interpretar resultados de vulnerabilidades

- La severidad ayuda a priorizar, pero no reemplaza el análisis del contexto.
- Una vulnerabilidad crítica en un servicio inaccesible desde la red relevante puede tener un riesgo diferente al de una vulnerabilidad similar expuesta públicamente.
- Revisar siempre el servicio, puerto, versión, evidencia y condiciones necesarias para explotar el problema.
- Distinguir entre vulnerabilidad confirmada, posible falso positivo y recomendación de configuración.
- Documentar la evidencia antes y después de la remediación.

Comparación: Lynis vs OpenVAS

- Lynis: visión principalmente local y orientada a la configuración y postura de seguridad del sistema.
- OpenVAS/Greenbone: visión principalmente de evaluación de vulnerabilidades desde la red, con posibilidad de análisis autenticado.
- Lynis ayuda a responder: «¿cómo está configurado este Linux y qué puedo endurecer?»
- OpenVAS ayuda a responder: «¿qué vulnerabilidades puedo detectar en este sistema desde una perspectiva de red?»
- Usadas juntas, las herramientas permiten contrastar configuración interna y exposición/vulnerabilidades.

Distribuciones Linux orientadas a seguridad

- Una distribución orientada a seguridad reúne herramientas para pruebas, análisis y evaluación de sistemas.
- Ejemplos conocidos incluyen Kali Linux y Parrot Security OS.
- Estas distribuciones no convierten automáticamente un sistema en seguro: proporcionan herramientas y un entorno preparado para realizar tareas de seguridad.
- Para esta práctica, la distribución puede utilizarse como estación de análisis desde la cual ejecutar herramientas contra el host Linux autorizado.

Tercera etapa: repetir desde una distro de seguridad

- Arrancar una distribución orientada a seguridad en una máquina virtual o equipo de laboratorio.
- Verificar conectividad con el host objetivo.
- Ejecutar uno de los analizadores utilizados anteriormente, manteniendo el mismo objetivo cuando sea posible.
- Comparar qué información aparece, qué herramientas están disponibles y qué cambia al trabajar desde una estación especializada.
- Separar claramente las capacidades de la distribución de las capacidades de la herramienta utilizada.

Reconocimiento

```
# 1. Escaneo de puertos TCP con detección de versión
nmap -sS -sV -O -p- 192.168.1.50 -oA target_scan

# 2. Auditoría de vulnerabilidades con scripts NSE
nmap --script vuln 192.168.1.50

# 3. Escaneo de servicios web expuestos
nikto -h http://192.168.1.50

# 4. Escaneo de cifrados TLS/SSL débiles
testssl.sh 192.168.1.50:443
```

¿Qué diferencias deberían observar?

- Una distro de seguridad facilita la instalación y disponibilidad de muchas herramientas especializadas.
- Puede incorporar utilidades de reconocimiento, análisis de red, evaluación de vulnerabilidades, forense y pruebas de seguridad.
- El resultado de Lynis debería depender principalmente del host auditado, no de que la estación sea una distro de seguridad.
- En un escaneo de red, la estación de análisis puede influir en conectividad, rutas, herramientas disponibles y facilidad para automatizar pruebas.
- La diferencia fundamental es el entorno de trabajo, no una supuesta «magia» adicional en el escáner.

¿Para qué usaría cada enfoque?

- Lynis: auditorías periódicas de servidores Linux, hardening y revisión de configuración.
- OpenVAS/Greenbone: gestión de vulnerabilidades y evaluación sistemática de hosts y servicios.
- Distro de seguridad: estación de trabajo para profesionales, laboratorios y ejercicios donde se necesitan muchas herramientas.
- HIDS: monitoreo continuo y detección de cambios o comportamientos sospechosos.
- Firewall: reducción de superficie de ataque mediante control de comunicaciones.
- La práctica de seguridad real combina estas capas según el riesgo y el contexto.

Metodología recomendada

- Preparar → medir → corregir → volver a medir.
- No modificar el sistema antes de capturar la línea de base.
- Registrar exactamente qué versión de cada herramienta y sistema operativo se utilizó.
- Realizar una única modificación significativa por iteración cuando el objetivo sea atribuir el cambio a una causa concreta.
- Conservar evidencia: capturas, reportes, comandos utilizados y explicación de la remediación.
- Validar siempre que la corrección no haya roto un servicio legítimo.

Seguridad y autorización

- Un escaneo de vulnerabilidades genera tráfico que puede ser interpretado como actividad hostil.
- No ejecutar OpenVAS, escaneos de puertos ni pruebas de seguridad contra redes o sistemas ajenos sin autorización.
- Para el laboratorio, utilizar máquinas virtuales, una red aislada o infraestructura explícitamente autorizada.
- Las credenciales utilizadas en OpenVAS deben ser específicas del laboratorio y no reutilizar contraseñas personales.
- La autorización y el alcance forman parte de la práctica de seguridad, no son un detalle administrativo.

Actividad práctica completa

- Parte A — Lynis: instalar, ejecutar, registrar línea de base, seleccionar una falencia, corregirla y repetir.
- Parte B — OpenVAS: crear Target, configurar Credentials, crear Task, ejecutar, analizar, corregir una falencia y repetir.
- Parte C — Distro de seguridad: repetir un análisis y comparar resultados y experiencia.
- Entregable: evidencias de los tres pasos, explicación técnica de una remediación y comparación antes/después.
- Conclusión: explicar qué herramienta utilizarían en un escenario real y por qué.

Checklist de evidencia

- Sistema operativo y versión del host.
- Topología o descripción breve del laboratorio.
- Resultado inicial de Lynis.
- Falencia seleccionada y justificación.
- Cambio aplicado y comandos/configuración relevantes.
- Resultado posterior de Lynis.
- Target, Task y Credentials configurados en OpenVAS.
- Resultado inicial y posterior de OpenVAS.
- Análisis desde la distribución orientada a seguridad.
- Comparación final y conclusiones.

Preguntas para discusión

- ¿Una puntuación alta de hardening significa que no existen vulnerabilidades?
- ¿Puede un host tener una buena configuración local y seguir siendo vulnerable desde la red?
- ¿Qué información adicional aporta un escaneo autenticado?
- ¿Qué riesgos introduce dejar habilitado un servicio que no se utiliza?
- ¿Cuándo conviene priorizar una vulnerabilidad sobre una recomendación de hardening?
- ¿Qué herramienta ejecutarían periódicamente y cuál usarían durante una evaluación puntual?

Resumen: protección de terminales Linux

- Los terminales son una parte fundamental de la superficie de ataque de una organización.
- La defensa en profundidad combina prevención, reducción de superficie, detección y evaluación.
- El firewall basado en host controla comunicaciones; HIDS observa actividad y cambios; los auditores y escáneres identifican debilidades.
- Lynis y OpenVAS ofrecen perspectivas diferentes y complementarias.
- La comparación antes/después permite demostrar el efecto concreto de una remediación.
- La seguridad efectiva es un proceso continuo de medir, corregir y volver a medir.

Cierre

La pregunta central no es solamente «¿qué vulnerabilidades tiene el host?», sino «¿qué podemos demostrar, corregir y volver a medir?».